

UF7

Criptografía

Ciberseguridad

ÍNDICE

Introducción.....	04
Objetivos.....	05
Mapa conceptual	06
1. Fundamentos de criptografía.....	07
1.1. Definición y necesidad de la criptografía.....	07
A. Confidencialidad.....	07
B. Integridad	08
C. Autenticación.....	08
D. No repudio.....	09
1.2. Criptografía clásica	10
A. Cifrado César.....	10
B. Cifrado Atbash.....	11
C. Cifrado Payfair.....	11
D. Otros	13
2. Criptografía en sistemas informáticos.....	15
2.1. Cifrado de clave secreta (simétrica).....	15
A. Algoritmos	16
B. Aplicaciones	17
C. Cifrado simétrico con Windows.....	17
D. Cifrado simétrico con Linux.....	21

2.2. Cifrado de clave pública (asimétrico)	23
A. Algoritmos de cifrado asimétrico	25
B. Aplicaciones del cifrado asimétrico	26
C. Encriptación asimétrica con Linux	26
2.3. Funciones hash	30
A. Verificación de la integridad de archivos	30
B. Almacenamiento seguro de contraseñas	32
C. Firmas digitales y certificación de documentos	33
D. Uso en tecnologías blockchain	33
E. Algoritmos de hash	34
3. Sistemas de identificación	35
3.1. Cifrar y firmar	35
3.2. Infraestructura de clave pública (PKI)	36
A. Estructura	36
B. Funcionamiento	38
3.3. Certificados digitales	39
Solucionario de los casos prácticos.....	44
Enlaces de interés	48
Glosario	49
Bibliografía	52

Introducción

En un mundo en el que cada segundo se transmite información sensible, la criptografía se convierte en una herramienta esencial. Proteger la confidencialidad, verificar la identidad y garantizar que los datos no han sido alterados es posible gracias a técnicas criptográficas que empleamos cada día, muchas veces sin saberlo. Cuando envías un mensaje por una app segura, cuando firmas digitalmente un documento, cuando tu navegador muestra el candado de seguridad en un sitio web, estás usando criptografía.

Comprender los principios que rigen la criptografía —confidencialidad, integridad, autenticación y no repudio— es el punto de partida. Desde los antiguos cifrados, como el César o el Atbash, hasta los algoritmos modernos, como RSA o SHA-256, la criptografía ha evolucionado para responder a los desafíos actuales. Aprenderás a aplicar cifrados simétricos y asimétricos, a generar y verificar firmas digitales, a usar funciones hash para comprobar la integridad de los datos y a configurar certificados digitales en sistemas reales.

¿Sabrías elegir el cifrado más adecuado según el contexto? En cualquier organización, te pedirán detectar vulnerabilidades criptográficas y aplicar soluciones prácticas para proteger la información en redes y servidores. Porque la criptografía no es solo teoría: es una competencia clave en ciberseguridad, redes y administración de sistemas.

Objetivos

X

Conocer el concepto y la necesidad de la criptografía, y aprender a cifrar textos con diferentes algoritmos no informáticos.

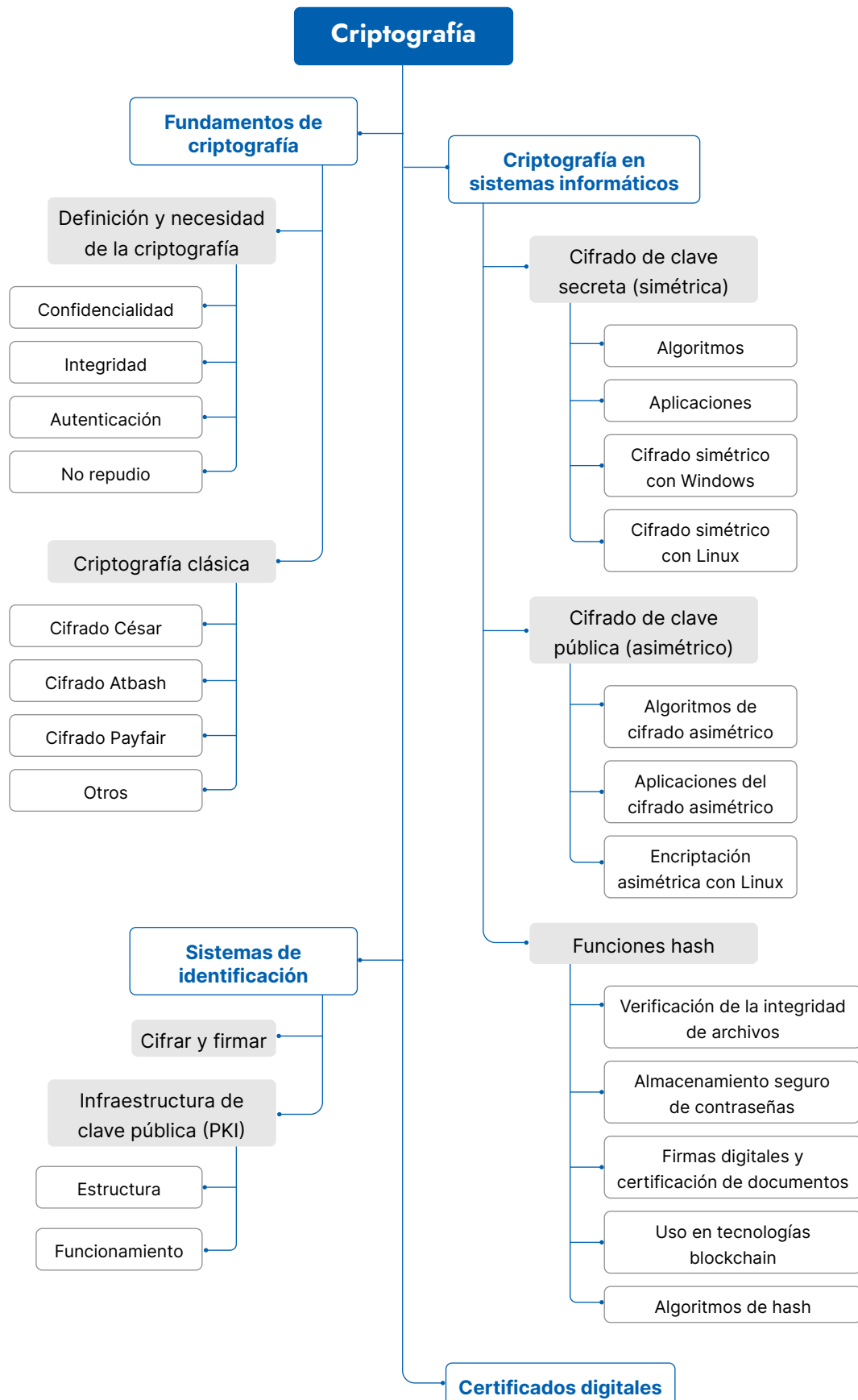
X

Ser capaz de generar claves simétricas y pares de claves asimétricas. Aprender a generar un hash y saber para qué sirve.

X

Conocer la importancia de las firmas digitales para mantener la autenticidad y el no repudio en una comunicación y entender la estructura PKI para generar certificados digitales confiables.

Mapa conceptual



01 Fundamentos de criptografía

1.1. Definición y necesidad de la criptografía

DEFINICIÓN

La **criptografía** es la disciplina que estudia las técnicas para proteger la información mediante el uso de algoritmos de cifrado, impidiendo su acceso a terceros no autorizados. Su origen se remonta a la antigüedad, cuando se utilizaban códigos y cifrados simples para proteger mensajes en contextos militares y políticos.

En la actualidad, el uso de criptografía es esencial en las comunicaciones digitales, las transacciones bancarias, el almacenamiento de datos sensibles y la seguridad en redes. El objetivo principal es garantizar los siguientes principios:

A. Confidencialidad

Solo los destinatarios **autorizados** pueden leer el mensaje.

EJEMPLO

- » Un cliente accede a su banca en línea. Los datos de su sesión (usuario, contraseña, movimientos bancarios) están cifrados con el protocolo TLS (Transport Layer Security) para que solo el servidor del banco y el cliente puedan leer la información. Si un atacante intercepta la comunicación, verá datos cifrados que no podrá entender.
- » En WhatsApp, los mensajes están cifrados de extremo a extremo con cifrado AES y Diffie-Hellman. Solo el remitente y el destinatario pueden leer el contenido, ni siquiera WhatsApp puede acceder a ellos.

B. Integridad

Se evita la **manipulación** de la información.

EJEMPLO

- » Un archivo descargado desde una página oficial incluye un hash SHA-256. Antes de instalarlo, el usuario verifica el hash comparándolo con el publicado en la web. Si el hash no coincide, significa que el archivo fue modificado o alterado por un tercero.
- » En una transacción bancaria, se usa HMAC (Hash-based Message Authentication Code) para asegurarse de que la cantidad y los datos del destinatario no se alteraron durante la transmisión.

C. Autenticación

Se verifica la **identidad** del emisor y el receptor.

EJEMPLO

- » Un **usuario** accede a su correo electrónico con autenticación de doble factor (2FA). Primero, ingresa su contraseña y luego introduce un código generado por Google Authenticator o enviado por SMS. Esto verifica que realmente es el propietario de la cuenta.
- » Un **servidor de correo electrónico** usa un certificado digital SSL/TLS firmado por una autoridad de certificación (CA). Así, los clientes pueden verificar que están conectándose al servidor legítimo y no a un impostor (ataque MitM – Man in the Middle).

D. No repudio

Un usuario **no puede negar** haber enviado o recibido un mensaje.

EJEMPLO

- » Un **gerente** firma digitalmente un contrato con su DNI Electrónico (DNle) o un certificado digital emitido por la FNMT (Fábrica Nacional de Moneda y Timbre-Real Casa de la Moneda). Como la firma digital usa un cifrado asimétrico y está validada por una CA, no puede negar haber firmado el documento.
- » En el **comercio electrónico**, cuando un usuario realiza una compra con tarjeta de crédito, el sistema de pago usa firmas digitales y autenticación biométrica (como la huella dactilar en Apple Pay o Google Pay). Esto impide que el comprador niegue haber realizado la transacción.

DEFINICIÓN

- » **TLS (Transport Layer Security)** es un protocolo de seguridad que cifra la comunicación entre dos dispositivos en Internet. Se usa en la banca en línea, correos electrónicos y redes privadas virtuales (VPN). Su antecesor fue SSL (Secure Sockets Layer).
- » **AES (Advanced Encryption Standard)** es un algoritmo de cifrado simétrico muy seguro, usado por gobiernos y empresas para proteger información sensible. Puede operar con claves de 128, 192 o 256 bits.
- » **Diffie-Hellman** es un protocolo de intercambio de claves que permite a dos partes generar una clave secreta compartida en un canal inseguro sin que un atacante pueda deducirla. Se usa en comunicaciones cifradas, como WhatsApp y VPN.
- » **Hash (resumen criptográfico)** es una función matemática que convierte un mensaje o archivo en un código único de longitud fija. Se usa para verificar que un archivo no ha sido modificado.
- » **SHA-256 (Secure Hash Algorithm 256 bits)** es una función hash muy usada en seguridad informática. Un cambio mínimo en los datos originales genera un hash completamente distinto.
- » **HMAC (Hash-based Message Authentication Code)** es una técnica de seguridad que usa una clave secreta combinada con una función hash para garantizar que los datos transmitidos no han sido alterados. Se usa en transacciones bancarias y en la seguridad de API.

1.2. Criptografía clásica

La criptografía clásica se basaba en **métodos manuales y mecánicos** para ocultar el significado de un mensaje, dificultando su lectura por parte de terceros no autorizados. En esa época, el cifrado consistía en modificar el orden o la apariencia de las letras del mensaje, utilizando reglas sencillas que el emisor y el receptor conocían previamente. Aunque estos métodos fueron eficaces durante siglos, con el avance de la computación se hicieron vulnerables, ya que podían ser descifrados con relativa facilidad mediante técnicas de criptoanálisis.

A. Cifrado César

Uno de los cifrados más conocidos de la antigüedad es el cifrado César, utilizado por el propio Julio César para proteger la correspondencia militar. Este sistema consiste en **desplazar cada letra del mensaje un número fijo de posiciones en el alfabeto**. Por ejemplo, si el desplazamiento es de tres posiciones, la letra A se convertiría en D, la B en E, y así sucesivamente. Así, un mensaje como «ATAQUE AL AMANECER» podría cifrarse como «DWDTXH DO DPDQHCHU».

Sin embargo, este método es **extremadamente débil**, ya que solo hay un número limitado de desplazamientos posibles, por lo que un enemigo podría probar todas las combinaciones y descifrar el mensaje en poco tiempo.

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C

Tabla 1. Tabla de conversión del cifrado César.

EJEMPLO

Si queremos cifrar la palabra «CIFRADO», aplicamos la sustitución según la tabla:

C → F

I → L

F → I

R → U

A → D

D → G

O → R

Texto cifrado: **FLIUDGR**.

B. Cifrado Atbash

Otro método utilizado en la criptografía clásica es el cifrado Atbash, que **invierte el orden del alfabeto** para transformar el mensaje. En este sistema, la A se reemplaza por la Z, la B por la Y y así sucesivamente.

De esta manera, una palabra como «SECRETO» se convertiría en «HVXIVGB». Este cifrado es aún más débil que el César, ya que **no usa claves variables y siempre sigue la misma sustitución**, lo que hace que cualquier persona que conozca el método pueda descifrar el mensaje con facilidad.

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
Z	Y	X	W	V	U	T	S	R	Q	P	O	N	M	L	K	J	I	H	G	F	E	D	C	B	A

Tabla 2. Tabla de conversión del cifrado Atbash.

EJEMPLO

Si queremos cifrar la palabra «CIFRADO», aplicamos la sustitución según la tabla:

C → X

I → R

F → U

R → I

A → Z

D → W

O → L

Texto cifrado: **XRUIZWL**.

C. Cifrado Playfair

Un sistema algo más sofisticado es el cifrado Playfair, que fue desarrollado en el siglo xix y se utilizó en varias guerras para proteger la información militar.

En este sistema, se emplea una matriz de 5 × 5 en la que se colocan las letras del alfabeto (combinando la I y la J en la misma celda).

Luego, el mensaje se divide en **pares de letras** y se aplica una serie de reglas para sustituirlas según su posición en la tabla. Este cifrado es más seguro que los anteriores porque no cifra letra por letra, sino en bloques de dos letras, lo que dificulta su análisis. Sin embargo, con técnicas de criptoanálisis, sigue siendo posible descifrarlo si se dispone de suficiente texto cifrado.

Por ejemplo, si usamos la palabra clave «CLAVE», la matriz se generaría así:

C	L	A	V	E
B	D	F	G	H
I/J	K	M	N	O
P	Q	R	S	T
U	W	X	Y	Z

EJEMPLO

Cifremos el mensaje «ATAQUE». Dividimos el mensaje en pares de letras. Si hay letras repetidas dentro de un par, se inserta una X entre ellas. Si el mensaje tiene un número impar de letras, se agrega una X al final:

AT – AQ – UE

Aplicamos las reglas de cifrado:

- » Si las letras están en la misma fila, se sustituyen por la siguiente letra a la derecha (la última vuelve al inicio de la fila).
- » Si las letras están en la misma columna, se sustituyen por la siguiente letra abajo (la última vuelve al inicio de la columna).
- » Si forman un rectángulo, se intercambian por las letras en la misma fila, pero en la otra columna.

Usamos la matriz anterior:

- » AT → A y T forman un rectángulo, por lo que se intercambian con las letras de la misma fila en la otra columna → VQ.
- » A está en la fila 1 y columna 3 → Se cambia por la letra en la misma fila, pero en la columna de T (columna 5) → V.
- » T está en la fila 4 y columna 5 → Se cambia por la letra en la misma fila, pero en la columna de A (columna 3) → Q.
- » AQ → A y Q también forman un rectángulo, por lo que se intercambian → LP.
- » UE → U y E forman otro rectángulo, por lo que se intercambian → ZC.

Texto cifrado: **VQLPZC**.

D. Otros

En el siglo xx, con el auge de las telecomunicaciones y la Segunda Guerra Mundial, se desarrollaron sistemas de cifrado mecánico mucho más complejos, como la máquina Enigma, utilizada por el ejército alemán.

Esta máquina consistía en un conjunto de rotores eléctricos que cambiaban la codificación de cada letra con cada pulsación de tecla, generando miles de combinaciones posibles. Se consideraba prácticamente invulnerable, pero fue finalmente descifrada por un equipo de matemáticos y criptógrafos liderado por **Alan Turing**, lo que supuso un punto de inflexión en la guerra.



VIDEO

¿Cómo funcionaba la máquina Enigma?:

<https://www.youtube.com/watch?v=ybkkiGtJmkM>

Aunque estos métodos fueron efectivos en su tiempo, todos comparten una debilidad común: sus reglas de cifrado son fijas y pueden ser descubiertas mediante análisis matemáticos o métodos de prueba y error.

Con la llegada de los ordenadores, la criptografía evolucionó hacia sistemas más avanzados, basados en claves más largas y algoritmos matemáticos mucho más complejos, dando origen a la criptografía moderna.

1

CASO PRÁCTICO

**CIFRADO CÉSAR EN UNA COMUNICACIÓN SECRETA**

Imagina que eres un agente encubierto y debes enviar un mensaje secreto al cuartel general para coordinar una operación. Dado que no dispones de medios electrónicos sofisticados y te encuentras en una zona con comunicaciones limitadas, decides utilizar un método clásico: el cifrado César. Este algoritmo, usado desde la Antigüedad, consiste en desplazar cada letra del mensaje un número fijo de posiciones en el alfabeto; típicamente es 3. Como no puedes comunicarte con nadie para establecer el desplazamiento, aplicas el algoritmo Cesar típico.

Mensaje original: ATAQUE AL AMANECER.

Recuerda que cada letra se reemplazará por la que se encuentre tres posiciones más adelante en el alfabeto. Por ejemplo: A $\rightarrow$ D, B $\rightarrow$ E, C $\rightarrow$ F, ..., X $\rightarrow$ A, Y $\rightarrow$ B, Z $\rightarrow$ C.

02 Criptografía en sistemas informáticos

Con la llegada de los ordenadores, la criptografía evolucionó hacia métodos más seguros y eficientes. La criptografía en sistemas informáticos se divide en dos categorías principales:

2.1. Cifrado de clave secreta (simétrica)

DEFINICIÓN

El cifrado de **clave secreta**, también conocido como **cifrado simétrico**, es un método de encriptación en el que se utiliza una misma clave tanto para cifrar como para descifrar la información. Es un sistema muy utilizado debido a su rapidez y eficiencia, pero presenta el desafío de garantizar una distribución segura de las claves entre los usuarios autorizados, es decir, que su principal vulnerabilidad es que en el momento de hacer llegar la clave de encriptación y desencriptación (que es la misma) al destinatario esta puede ser interceptada.



¿SABÍAS QUE...?

Para asegurar el uso del cifrado simétrico debemos enviar la clave al destinatario por un **sistema diferente** a aquel con el que enviamos la comunicación cifrada. No podemos usar el mismo canal porque, de ser así, si nos interceptan el mensaje, nos interceptan la clave.

Para comprender mejor este proceso, podemos imaginar una situación cotidiana. Supongamos que una empresa necesita enviar un documento confidencial a su sucursal en otra ciudad. Para proteger la información, el remitente cifra el documento utilizando una clave secreta. Luego, el archivo cifrado se envía a la sucursal, donde el receptor lo descifra utilizando la misma clave.

Este proceso se puede describir en tres pasos principales:

1. El emisor aplica un algoritmo de cifrado al mensaje utilizando una clave secreta, transformando el contenido en un texto ilegible para cualquier persona que no tenga la clave.
2. El mensaje cifrado es enviado al receptor a través de un canal de comunicación.
3. El receptor, con la misma clave secreta, descifra el mensaje y recupera la información original.



WEB

Más información sobre cifrado simétrico:

https://www.redseguridad.com/actualidad/cifrado-simetrico-que-es-usos-tecnicas_20231104.html

A. Algoritmos

Existen diversos algoritmos para implementar el cifrado simétrico. Algunos de los más utilizados son:

- » **DES (Data Encryption Standard):** fue uno de los primeros algoritmos ampliamente adoptados, pero hoy en día se considera obsoleto debido a su baja seguridad ante los avances en el poder de cálculo de los ordenadores modernos.
- » **AES (Advanced Encryption Standard):** es el estándar de cifrado actual, usado en aplicaciones militares, bancarias y gubernamentales debido a su alta seguridad. Por ejemplo, cuando una aplicación bancaria cifra la información de una transacción para evitar que terceros la intercepten, está usando AES.
- » **Blowfish y Twofish:** son alternativas seguras y rápidas, utilizadas en software de cifrado como gestores de contraseñas o aplicaciones de seguridad.



WEB

Información sobre Blowfish:

https://www.schneier.com/academic/archives/1998/12/the_twofish_encrypti.html

B. Aplicaciones

El cifrado de clave secreta se emplea en diversas áreas para proteger la información:

Protección de datos en dispositivos

Muchos sistemas operativos utilizan cifrado simétrico para proteger la información almacenada en discos duros y dispositivos móviles. Por ejemplo, en los teléfonos modernos, los datos se cifran para evitar que sean accesibles sin la autenticación del usuario.

Seguridad en redes wifi

Los protocolos WPA2 y WPA3, que protegen las redes inalámbricas, utilizan cifrado simétrico para garantizar que solo los usuarios autorizados puedan acceder a la red.

Comunicaciones seguras mediante VPN

Las redes privadas virtuales (VPN) usan cifrado simétrico para proteger el tráfico de datos entre el usuario y el servidor, asegurando que la información no pueda ser interceptada por terceros.

C. Cifrado simétrico con Windows

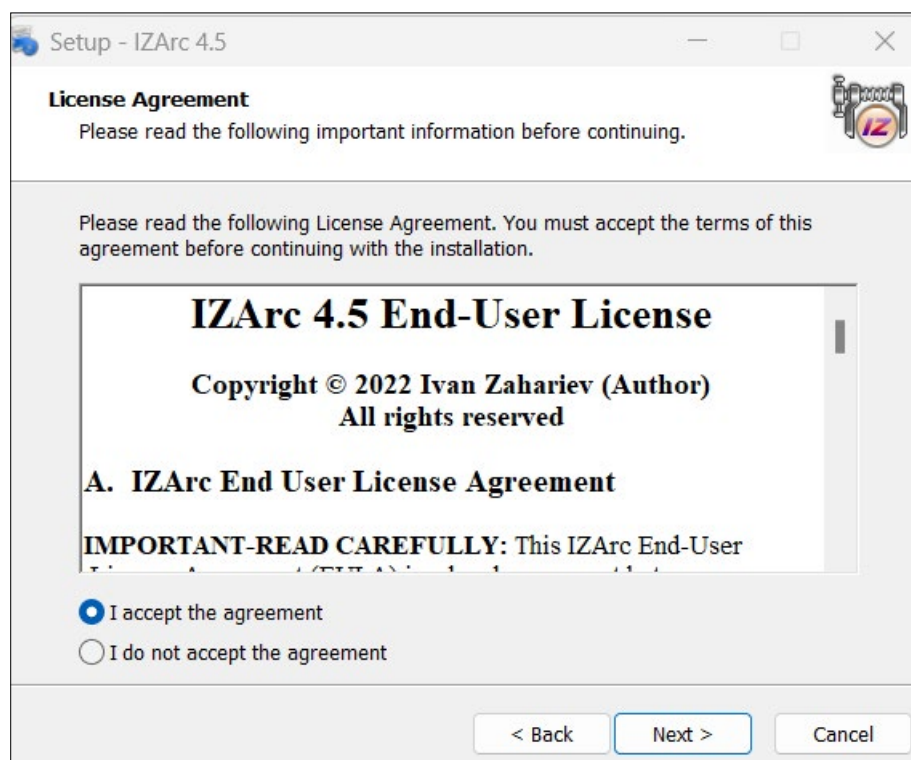


WEB

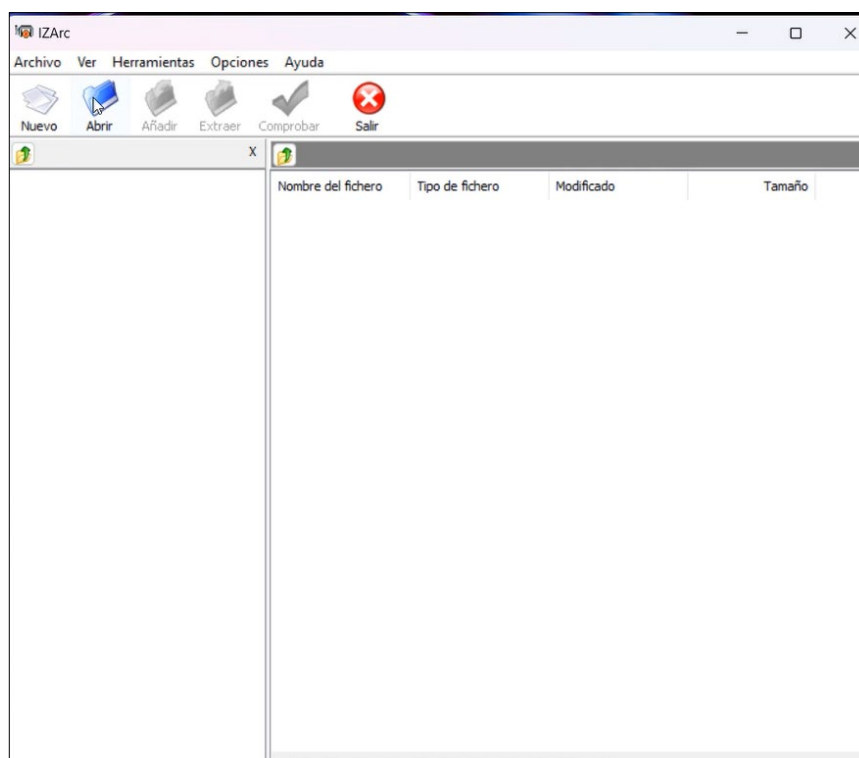
Podemos descargar la herramienta **IZArc**, que es tanto un compresor como un encriptador, en el siguiente enlace:

<https://www.izarc.org/downloads>

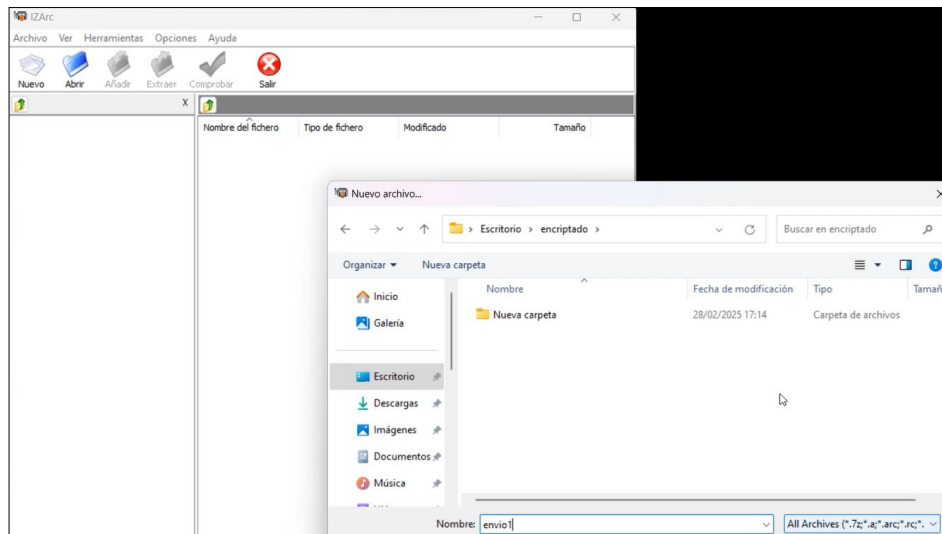
Se instala el paquete:



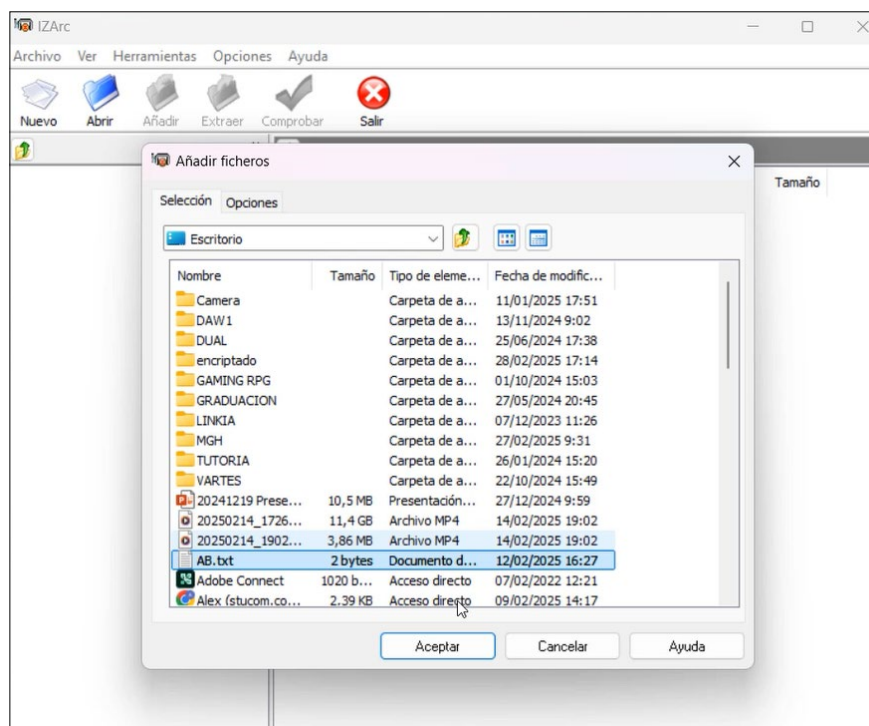
Una vez instalada la aplicación, la ejecutamos:



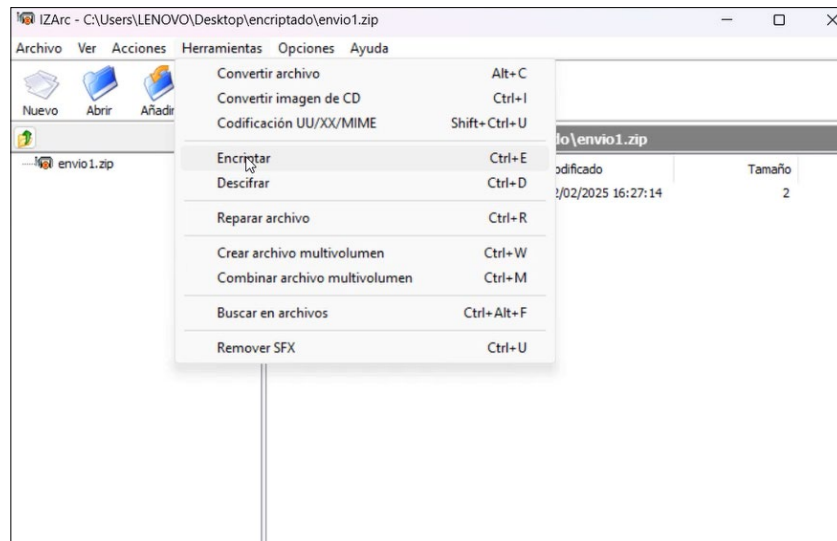
Creamos un nuevo archivo que contendrá el fichero encriptado:



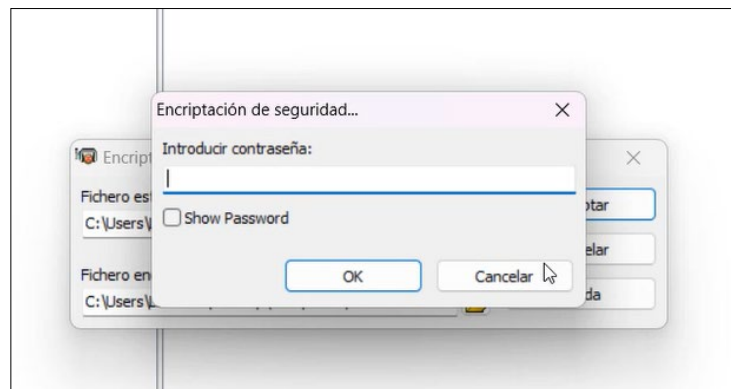
Se añade el fichero que se quiere encriptar:



Ahora se crea la clave simétrica, con la opción *Encriptar*:



Se incluye la clave:

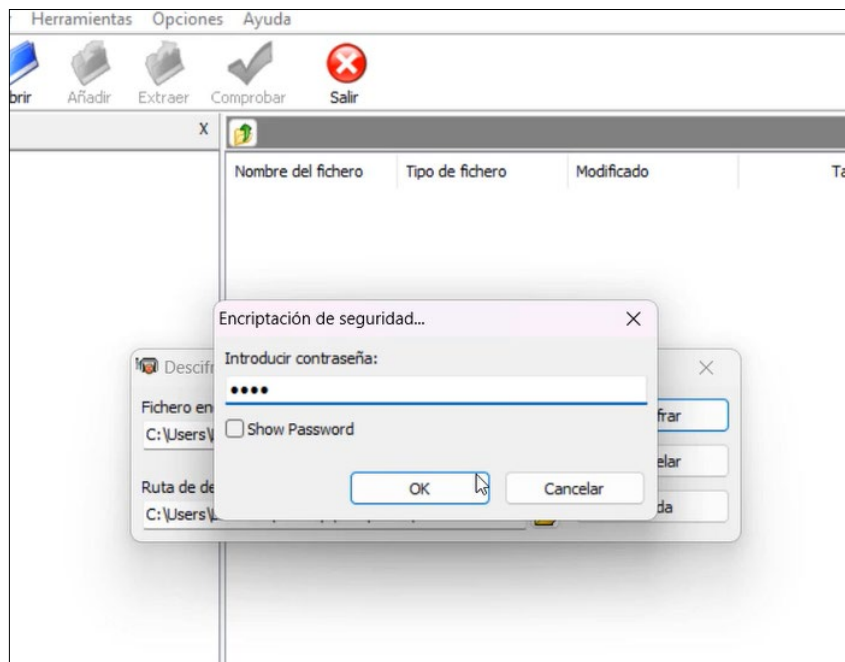


A partir de aquí, tenemos el mensaje encriptado, que podemos enviar al destinatario sin miedo a que sea descifrado por quien no conozca la clave.

Una vez que llega al destino, con el mismo programa instalado:



Se introduce la clave:



Y tenemos acceso al fichero descriptado.

D. Cifrado simétrico con Linux

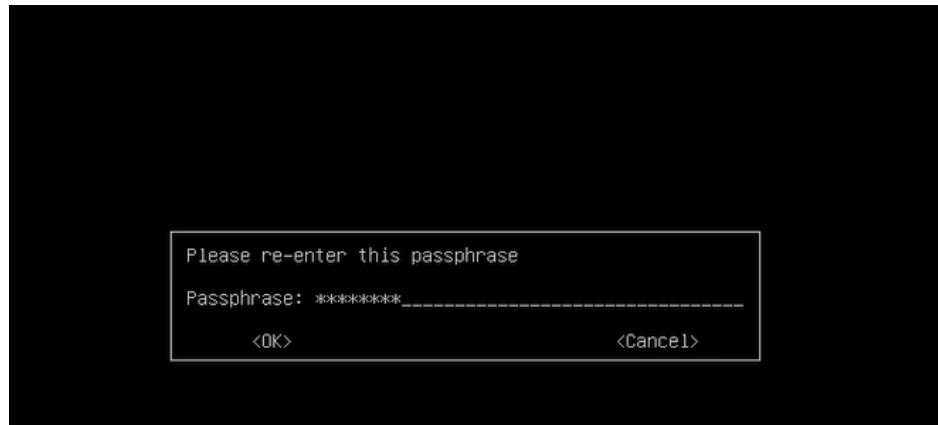
En un entorno Linux creamos primero el archivo de texto descriptado, como se ve a continuación.

```
root@stucom:/home/stucom# echo "esto es una prueba" > fichero
root@stucom:/home/stucom# ls
fichero
root@stucom:/home/stucom# cat fichero
esto es una prueba
root@stucom:/home/stucom#
```

Con el comando **gpg** creamos una clave simétrica y la aplicamos al archivo que se va a cifrar:

```
root@stucom:/home/stucom# gpg --symmetric fichero
```

Nos pedirá una clave:



Y vemos como el sistema ha creado un archivo GPG encriptado.

```
root@stucom:/home/stucom# ls
fichero fichero.gpg
```

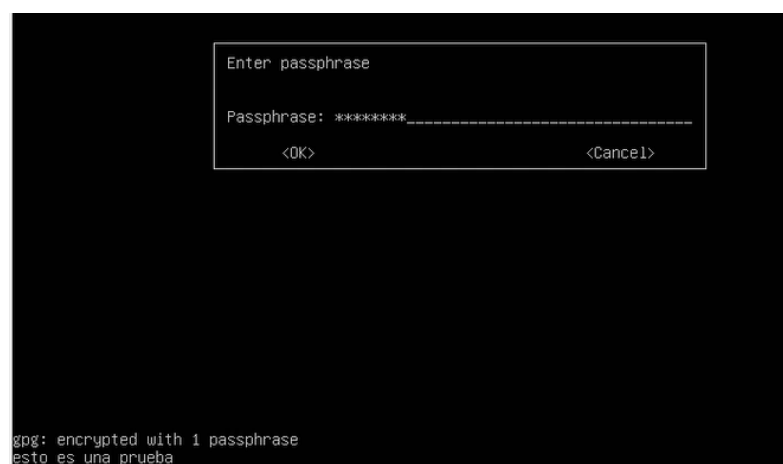
Este será el archivo que vamos a enviar. En este caso lo enviamos por FTP a un destinatario, como se ve en la imagen:

```
root@stucom:/home/stucom# ftp 10.30.100.99
Connected to 10.30.100.99.
220 (vsFTPd 3.0.5)
Name (10.30.100.99:stucom): alex
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> put fichero.gpg
local: fichero.gpg remote: fichero.gpg
229 Entering Extended Passive Mode (|||15878|)
150 Ok to send data.
100% |*****| 96 390.62 KiB/s 00:00 ETA
226 Transfer complete.
96 bytes sent in 00:00 (4.61 KiB/s)
ftp> qu_
```

A partir de este momento, en el servidor destinatario tenemos el archivo GPG, que solo podremos leer si lo desencriptamos con GPG y la clave.

```
root@srv:/home/alex# gpg --decrypt fichero.gpg _
```

Finalmente, tenemos el contenido del archivo desencriptado.



2.2. Cifrado de clave pública (asimétrico)

El **cifrado de clave pública**, también conocido como **cifrado asimétrico**, es un método de encriptación que utiliza un par de claves diferentes: una clave pública, que se emplea para cifrar los datos, y una clave privada, que solo el destinatario conoce y que se usa para descifrarlos.

Este tipo de cifrado elimina el problema del cifrado simétrico en cuanto a la transmisión de una única clave que cifra y descifra.

Este sistema ofrece una mayor seguridad para la transmisión de información en redes inseguras, como Internet, aunque es más lento en comparación con el cifrado simétrico debido a la complejidad de sus algoritmos.

Las claves de esta encriptación son dos:

Privadas

Solo las conoce el propietario
y no las comparte con nadie.

Públicas

Son compartidas y las conoce
todo el mundo.

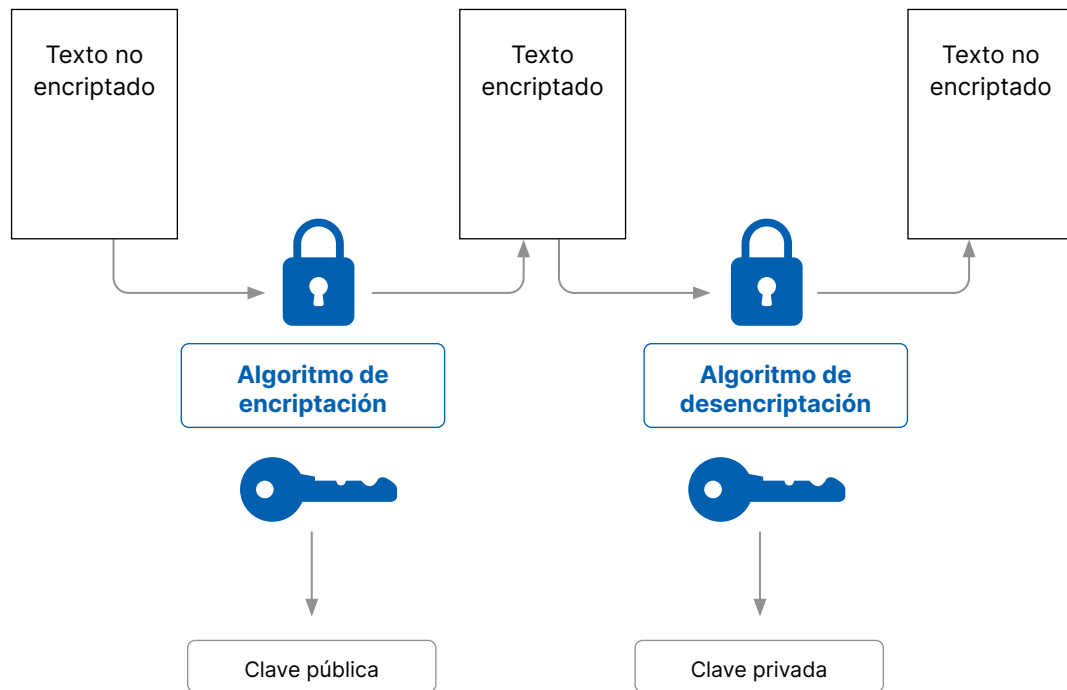
Lo que se encripta con la clave privada se desencripta con la clave pública y lo que se encripta con la clave pública se desencripta con la clave privada.



WEB

Encriptación asimétrica:

<https://www.ionos.es/digitalguide/servidores/seguridad/cifrado-asimetrico/>.



Esquema 1. Clave pública y privada.

El transmisor encripta el mensaje con la **clave pública del receptor** (dispone de ella porque es pública) y el receptor lo desencripta con su propia clave privada (solo la tiene él). En este tipo de encriptación no necesitamos un canal seguro para compartir la clave, porque la única que ha de distribuirse es la pública. Normalmente se crea la clave pública a partir de una clave privada, pero no ha de ser posible obtener una privada desde una pública.

Estos sistemas permiten también asegurar la integridad y la autenticación, no solo la confidencialidad, pero, por el contrario, los algoritmos son más complejos que los simétricos, por lo que la comunicación no es tan rápida.

Imaginemos dos usuarios, A y B, cada uno con su par de claves. Si A quiere enviar un mensaje a B garantizando la **confidencialidad**, A envía el mensaje cifrado con la clave pública de B, de modo que solo B podrá descifrarlo con su clave privada, por lo que A estará seguro de que lo ha recibido B. Así se garantiza la confidencialidad. En cambio, si queremos garantizar la **autenticación**, A enviará un mensaje con su clave privada y B lo descifrará con la clave pública de A. Así sabrá seguro que el mensaje ha sido originado por A.

Por otro lado, piensa en un usuario quiere **enviar un mensaje confidencial a su banco**. En este caso, sigue estos pasos:

- » El usuario cifra el mensaje utilizando la clave pública del banco, la cual es de conocimiento público y puede ser compartida sin riesgo.
- » El mensaje cifrado viaja a través de la red. Aunque un atacante lo intercepte, no podrá descifrarlo sin la clave privada del banco.
- » El banco recibe el mensaje y lo descifra con su clave privada, asegurando que solo el receptor pueda leer su contenido.

Este mecanismo garantiza la confidencialidad y la seguridad de la información transmitida.

A. Algoritmos de cifrado asimétrico

Existen diversos algoritmos de cifrado asimétrico, cada uno con características y aplicaciones específicas. Algunos de los más utilizados son:

- » **RSA (Rivest-Shamir-Adleman)**: se basa en la dificultad de factorizar grandes números primos, lo que lo hace altamente seguro. Es ampliamente utilizado en comunicaciones seguras y certificados digitales.
- » **Diffie-Hellman**: permite el intercambio seguro de claves entre dos partes, incluso si la comunicación está siendo observada por terceros. Es clave en el establecimiento de sesiones seguras en protocolos como SSL/TLS.
- » **ECC (criptografía de curvas elípticas)**: ofrece el mismo nivel de seguridad que RSA, pero con claves mucho más pequeñas, lo que lo hace más eficiente en dispositivos con recursos limitados, como teléfonos móviles y tarjetas inteligentes.

B. Aplicaciones del cifrado asimétrico

El cifrado asimétrico es una tecnología fundamental en la seguridad digital moderna y se usa en diversas aplicaciones:

- » **Certificados digitales y autenticación en sitios web:** los protocolos SSL/TLS utilizan el cifrado asimétrico para proteger las conexiones entre usuarios y servidores, asegurando la privacidad en transacciones bancarias y comercio electrónico.
- » **Seguridad en correos electrónicos:** tecnologías como PGP (Pretty Good Privacy) y S/MIME (Secure/Multipurpose Internet Mail Extensions) emplean el cifrado asimétrico para garantizar la confidencialidad y la autenticidad de los correos electrónicos.
- » **Firmas digitales y documentos electrónicos:** los documentos electrónicos pueden ser firmados digitalmente utilizando una clave privada, permitiendo verificar la identidad del remitente y la integridad del documento sin necesidad de compartir información confidencial.

C. Encriptación asimétrica con Linux

Vamos a ver un ejemplo de cómo aseguraríamos la confidencialidad enviando un mensaje encriptado con la clave pública del receptor y que solo este puede desencriptar con su clave privada.

Lo primero de todo es crear el par de claves en el receptor.

```
root@srv:/home/alex# gpg --full-generate-key
gpg (GnuPG) 2.2.27; Copyright (C) 2021 Free Software Foundation, Inc.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.

gpg: directory '/root/.gnupg' created
gpg: keybox '/root/.gnupg/pubring.kbx' created
Please select what kind of key you want:
  (1) RSA and RSA (default)
  (2) DSA and Elgamal
  (3) DSA (sign only)
  (4) RSA (sign only)
  (14) Existing key from card
Your selection? 1
RSA keys may be between 1024 and 4096 bits long.
What keysize do you want? (3072)
Requested keysize is 3072 bits
Please specify how long the key should be valid.
  0 = key does not expire
  <n> = key expires in n days
  <n>w = key expires in n weeks
  <n>m = key expires in n months
  <n>y = key expires in n years
Key is valid for? (0) 0
Key does not expire at all
Is this correct? (y/N) y

GnuPG needs to construct a user ID to identify your key.

Real name: Alfonso
Email address: alfonso@uax.net
Comment: text
You selected this USER-ID:
  "Alfonso (text) <alfonso@uax.net>"

Change (N)ame, (C)omment, (E)mail or (O)kay/(Q)uit?
```

Con el comando `gpg --full-generate-key` creamos la clave privada incluyendo los datos del receptor.

A continuación, el sistema pide una frase de paso para crear la clave.



Una vez creada la clave privada, creamos la pública para distribuirla:

```
root@srv:/home/alex# gpg --armor --export alfonso@uax.net > public.key
root@srv:/home/alex#
```

Aquí se puede ver:

```
ftep+q/8rtWTz0g9KTuK461j7VoPzBkYmGnZif/dwodGN9n6s1uxFqH15Mu1IH+h
hbvHx4DctArjHrgJnd9WNmxUM2rgNSEUB15m856EBPxxNNY1/fI804QwKB0LwIOE
ZcsbosCH+5BHXF6Wv2+L41gpbvaVItYbhOLyusmi0dq0xq75H3vbJ9V1vutQbx0T
Sm74QvcU3MLHmUQ5G1U21K11TqWzVd1ctJJ9YxG9Mt8PaB1Xuk0M/11gxYJxkJSC
C2NWrGD+vnnRC+cAEQEAAbQgQXmb25zbyAodGV4dCkgPGFs2m9uc29AdWf4Lm51
pD6JAc4EEwEKA0gHIQqth7ZRH5f57EUG/hSyJaIfD0ApMQUC28IjWAIBAUULCQgH
AgYVCgkICwTEFGIDAQIeAQIXgAAKRCRCyJaIfDDApMaX0DACLJA1R9WMjVt1aYzQZ
XL3x3ILTI5EAPLvMwuM4exyYJHoGmZULnYftwp1oC6YJ9rd2xHQ0YefTE/1S31h
e1NECGG8owq28H+e/VGLBq+vwFr4SjTaE1BmHLFTZWsANEfu7Dm3YzSGGXEKGF
dfEs0HYA1vtYcJ+1PTMI5BTt9n7yCXgXIfaxrkxs9R+HCqUBaanHgcerWWv5p6G
ec/Vz0W3s5KxI5cekUpzG1oG05LX1q57HVQBwX+mAlckCQp0E22VASWz9Bhd4fQx
mP7PeHXKw3vukgfdjWEobJ7mNt0eo6/Q1o/1JKRuszcycKoaD2b1fgh0myV3L+I6G
XmGkIC6mRBHwVuvmvH6Gmktr/nEBKK8TFYHJsn5b3vYFW2nyjJaDI7zrzDqeIL
DIxNedNe+mmp48X1yJ01qSm51ud0Eto1138mf6RJjmoVnqt3JYV4+uIcISF6XTQ
Uj79tLYq0ijjEgHeLbYr7XYtn7w94Y+OLJHW9P1H2Wn0X1m5AY0E28IjWAEAMAMK
FyxmhawylrrIrrzALCDPPj4PYVP/S/v1mGHoPzA+HufmBrIIZVp6ejeIaxHAKFPr
MmjL1XBnLKyyMyARhVh8tsSVxo6W0CCzyVTMnD6g3CnmP2RSaug7AyH6vM1xYQrE
+u/23qtT712f1qsRCTwUsuDGr84ez256nTK8BhYD31cmCN342KJS+uFrFbSWLD/
aS0ZMnrTkwpcKwbAPhw704zTHmD1XYqgXontgTy2GpX7pGQ8zo0gskRneBIs0t3
H1nD9pQh59U9+nFkJPe4FEjx8Ps415a6H5GAbExIFsvro9F9vaf/hGhJ1t7DIGd
YpesH00U5FsyEQW3HfAJ5XdoJcYhW12gqta3aV+ddz4fSbrSsEJNXI30DN+lr
aSnBAq+KXB712E8DBn9f+H4VbGJ+BwGooQXep6M4cB2soX/5d2W5m+6C/A31hTJv
tduygPJ4rXyHnQP62H3E3gRvYrg+IjUNn1oh80vfrVSIHu839inIPRhZUGrQJQAR
AQAB1QG2BBgBCAgFIEELYe2UR+X+exLhv4Us1W1HwuuKTEFAmfcI1gCGuWACgkG
s1W1HwuuKTEFAmfcI1gCGuWACgkGs1W1HwuuKTEFAmfcI1gCGuWACgkGs1W1HwuuK
CkbZjkMbFIsuW3a1D2j8yo10bJYqY9QDMhJfSKsmu0WBy1f8Uho3rN8DhP96H7ev
YVnrk7L7t6qRjabKud2AJiac0yYJusd2RCpdfJGJEQWQrgWqYnF0rBVmWymHMKDTiY
uSuDDYJewG8REFyImovoUJwJcCasuX4gIof412sky13zNW9uULXu7e78SqaC49
ZPIJH++rF0ZBkrjccFaaHra0VfcQL1KE0Un71IHNB/F01PB711Sffdv64G/fAvue
+MuMm3T/T848S6PdZLfYJd20b0uJWUZABYDmB01+uM79FP5mAjQ6x0fS3J8AFJd91
pLT0E5YKmScGb0+p3E1EadbKpayhTGKxyL0xH20nG6EKfPg+MCPgUS57FkvuLNo
D071tKEzig/Guid4X62EY1e19THdpdCVKYcVugSugGbaqHKfYb5JN1In04sEYQY5t6v
xqmyarPhbnZuW23
=MuP/
-----END PGP PUBLIC KEY BLOCK-----
```

Ahora se transfiere la clave pública al remitente, que encriptará el mensaje con la pública para enviarlo al destinatario; lo hacemos, como se ve, con el comando **scp**:

```
root@srv:/home/alex# scp public.key stucom@10.0.2.13:/home/stucom
stucom@10.0.2.13's password:
public.key                               100% 2436   792.6KB/s   00:00
root@srv:/home/alex# _
```

El siguiente paso es importar la clave pública en el remitente, para que forme parte del sistema:

```
root@stucom:/home/stucom# gpg --import public.key
gpg: /root/.gnupg/trustdb.gpg: trustdb created
gpg: key B225A21F0C302931: public key "Alfonso (text) <alfonso@uax.net>" imported
gpg: Total number processed: 1
gpg:      imported: 1
root@stucom:/home/stucom# _
```

Y ya se puede encriptar con esa clave pública:

```
root@stucom:/home/stucom# gpg --output archivo.txt.gpg --encrypt --recipient alfonso@uax.net archivo.txt
gpg: 93583872955A424E: There is no assurance this key belongs to the named user

sub rsa3072/93583872955A424E 2025-02-28 Alfonso (text) <alfonso@uax.net>
Primary key fingerprint: 2D87 B651 1F97 F9EC 4B86  FE14 B225 A21F 0C30 2931
Subkey fingerprint: 080B A67A 054D 94B7 3F52  AC19 9358 3872 955A 424E

It is NOT certain that the key belongs to the person named
in the user ID. If you *really* know what you are doing,
you may answer the next question with yes.

Use this key anyway? (y/N) y
root@stucom:/home/stucom# _
```

Ahora tenemos el mensaje encriptado, con extensión **.gpg**, que enviaremos al destinatario; en este caso lo enviamos vía **FTP**:

```
root@stucom:/home/stucom# cat archivo.txt
mensaje a enviar
root@stucom:/home/stucom# cat archivo.txt.gpg
X8r+ZBN
++jFe+      +$5+]*5kn6++/rY"++{Y+L+tp#++q4++9+Sve+SjH!o+y*%+_+w+++++*****h+n
++6cKL++2+E++[A++%+,++h++%+++d+++f$Fq+Z++++++1Q+j+++k+eeZ++++:R+Y"Off++>++++f+@'+B:)++?+1+
+U\+r+I++xTnqJ++@++t++++G++ucJ++o+++++j++d++x+dgu++++&u++{+E+Q++>'++@,++4+++++E
++-++{+S+N  Kt+g+'HWDé~
FbT1a b^e-; '@:EI08AIÜPF:s"2ä7Ü:9FçI?ã<:Ï-EêÜD'PÜÖW'üPc0ÿöc!`7+³i+ÜäYö0G!FêJ|Lä-Y:³A=#6N2 _ÿüé]a
+H+@5`++ZAd+(lvw++|s(++jJ+++root@stucom:/home/stucom# ftp 10.0.2.14
Connected to 10.0.2.14.
220 (vsFTPd 3.0.5)
Name (10.0.2.14:stucom): alex
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||23759|)
150 Here comes the directory listing.
-rw----- 1 1000 1000 2436 Feb 28 21:00 public.key
226 Directory send OK.
ftp> put archivo.txt.gpg
local: archivo.txt.gpg remote: archivo.txt.gpg
229 Entering Extended Passive Mode (|||57278|)
150 Ok to send data.
100% |*****| 488 0.99 MiB/s 00:00 ETA
226 Transfer complete.
488 bytes sent in 00:00 (95.56 KiB/s)
ftp> quit
221 Goodbye.
root@stucom:/home/stucom# _
```

En esta imagen se ve el contenido del mensaje sin encriptar, el mensaje encriptado y el envío por FTP al destinatario.

Ahora, en el destinatario, desencriptamos con la clave privada del receptor.

```
root@srv:/home/alex# gpg --output archivo.txt --decrypt archivo.txt.gpg _
```

Para desencriptar, necesitamos la frase de paso que establecimos:



Y, finalmente, tenemos el texto desencriptado en el destino:

```
root@srv:/home/alex# ls
archivo.txt  archivo.txt.gpg  public.key
root@srv:/home/alex# cat archivo.txt
mensaje a enviar
root@srv:/home/alex#
```

EJEMPLO

Este proceso puede ayudarnos a mantener la confidencialidad. Por ejemplo, imaginemos que trabajas en una empresa que está desarrollando un nuevo producto innovador. El director de innovación necesita enviar un **informe detallado con diseños, estrategias y datos financieros sensibles** a un socio estratégico. Si este informe se envía sin cifrar, cualquier persona que intercepte la comunicación —por ejemplo, a través de una red wifi pública— podría acceder a toda esa información y utilizarla para fines malintencionados, poniendo en riesgo la competitividad de la empresa. Sin embargo, si el director cifra el documento utilizando la clave pública del socio, el informe se transforma en un conjunto de datos ininteligibles para cualquiera que lo intercepte. Solo el socio, que posee la correspondiente clave privada, podrá descifrar el mensaje y acceder a la información original. Este ejemplo ilustra claramente la necesidad de cifrar la información para mantener la confidencialidad y proteger datos críticos frente a posibles ataques o interceptaciones.

2.3. Funciones hash

Las **funciones hash** son algoritmos matemáticos que, a partir de cualquier entrada de datos, generan un resumen único de tamaño fijo. Este resumen, conocido simplemente como *hash*, se utiliza para verificar la integridad de la información, ya que permite detectar si un mensaje ha sido modificado. Una de las características más importantes de estas funciones es que, aunque dos mensajes diferentes pueden generar valores de salida distintos, el mismo mensaje siempre produce el mismo hash, lo que facilita la comparación y la validación de datos.

Una de las propiedades fundamentales del hash es la **irreversibilidad**: una vez que se ha generado el hash de un mensaje, resulta prácticamente imposible reconstruir el mensaje original únicamente a partir de ese valor. Esta propiedad es crucial en el almacenamiento seguro de contraseñas, ya que, incluso si alguien obtiene el hash, no podrá deducir la información sensible que se usó para generarlo. Además, el determinismo asegura que cada vez que se procese el mismo mensaje se obtenga el mismo hash, lo que resulta esencial para comprobar la integridad de los datos en sistemas de seguridad.

Otro aspecto importante es el **efecto avalancha**, que significa que pequeños cambios en el mensaje original producen grandes diferencias en el hash resultante. Este comportamiento permite detectar incluso modificaciones mínimas, garantizando una mayor confiabilidad en la verificación de la integridad.

A. Verificación de la integridad de archivos

Cuando se descarga un archivo de Internet, a menudo se proporciona un valor hash (por ejemplo, SHA-256) junto con el archivo. Después de la descarga, se puede usar una herramienta como `sha256sum` en Linux para calcular el hash del archivo descargado y compararlo con el valor publicado.

Si ambos coinciden, significa que el archivo no ha sido alterado durante la transferencia.

Es cierto que no se puede **conocer el hash de un archivo que esté publicado en Internet** a menos que el proveedor lo suministre; por ejemplo, en la zona de descarga de Ubuntu se pueden ver los hashes de los archivos por descargar.

Supongamos que descargas un archivo llamado wubi.exe y se te indica que su hash SHA-256 es:



La página de descargas es:

Servicio de replicas de RedIRIS - ftp.rediris.es		
ubuntu-14.04.6-server-amd64.iso.zsync	2019-03-07 15:43	1.2M
ubuntu-14.04.6-server-amd64.jigdo	2019-03-07 15:43	127K
ubuntu-14.04.6-server-amd64.list	2019-03-05 00:49	92K
ubuntu-14.04.6-server-amd64.manifest	2019-03-05 00:36	5.5K
ubuntu-14.04.6-server-amd64.metalink	2019-03-07 15:48	47K
ubuntu-14.04.6-server-amd64.template	2019-03-05 00:49	68M
ubuntu-14.04.6-server-i386.iso	2019-03-05 00:51	609M
ubuntu-14.04.6-server-i386.iso.torrent	2019-03-07 15:44	24K
ubuntu-14.04.6-server-i386.iso.zsync	2019-03-07 15:44	1.2M
ubuntu-14.04.6-server-i386.jigdo	2019-03-07 15:44	123K
ubuntu-14.04.6-server-i386.list	2019-03-05 00:51	89K
ubuntu-14.04.6-server-i386.manifest	2019-03-05 00:38	5.4K
ubuntu-14.04.6-server-i386.metalink	2019-03-07 15:48	47K
ubuntu-14.04.6-server-i386.template	2019-03-05 00:51	64M
wubi.exe	2014-04-14 18:04	2.4M

En el terminal de Windows, si deseamos saber el hash del archivo descargado (wubi.exe), ejecutamos la instrucción siguiente:

```

C:\Users\LENOVO\Downloads>certutil -hashfile "wubi.exe" sha256
SHA256 hash de wubi.exe:
bc3b20ad00f19d0169206af0df5a4186c61ed08812262c55dbca3b7b1f1c4a0b
CertUtil: -hashfile comando completado correctamente.
  
```

Si el resultado coincide con el hash proporcionado, como es el caso, podemos estar seguros de que el archivo no ha sido modificado durante la descarga por la intercepción de nadie.

B. Almacenamiento seguro de contraseñas

En lugar de guardar contraseñas en texto plano, **los sistemas las almacenan como valores hash**. Cuando un usuario inicia sesión, el sistema genera el hash de la contraseña ingresada y lo compara con el hash almacenado en la base de datos. Esto protege la información, ya que, incluso si un atacante accede a la base de datos, no obtendrá las contraseñas originales.

Para obtener el hash de una contraseña tal como se almacena en Ubuntu, debemos tener privilegios de administrador, ya que el archivo `/etc/shadow` solo es accesible por el usuario root.

El archivo `/etc/shadow` contiene una línea por cada usuario, donde el segundo campo es el hash de la contraseña. El formato general es:

```
usuario:$id$salt$hash:...
```

Donde:

- » `$id` indica el algoritmo utilizado:
- » `$1$` para MD5.
- » `$5$` para SHA-256.
- » `$6$` para SHA-512 (el más usado en Ubuntu).
- » `$y$` o `$7$` para `yescrypt`.
- » `salt` es un valor aleatorio que se añade para dificultar ataques de diccionario.
- » `hash` es el resultado del proceso de encriptación.

Para ver el contenido, ejecutamos en el terminal:

```
sudo cat /etc/shadow
```

Buscamos la línea correspondiente al usuario de interés.

En el ejemplo:

```
stucom:$6$xf1d3PSUwpXKwb5C$IPYan4HBmKzZU1zBEjks1mbae0i5UKP091X28ckBRm4ytk1LRDQhTG7H125XYS3aHirjPCF
tq2TLFqWo3jA0:20136:0:99999:7:::
lxd:!:20136:0:99999:7:::
alex:$y$j9T$0EET9J0xjJz3yBevBJizD.$tiHB9N/N/1Rpu1/95NYRSC.1KdbsJk5zSPLOVCNJ8U9:20147:0:99999:7:::
```

Vemos el usuario `stucom`, encriptado con `$6$`, es decir, con SHA-512. Después, entre `$` tenemos el valor de SALT y, tras el `$`, tenemos el hash del password.

Para **generar un hash de esa contraseña** con ese hash, podemos usar `openssl`, o, si se usa `yescrypt`, tendremos que utilizar el comando `mkpasswd` que está incluido en el paquete `whois` (para usarlo, hemos de instalar `apt-get install whois`).

Para encontrar el pass de **stucom**, indicamos el tipo de algoritmo de encriptación (sha-512) y el SALT que el sistema añadió para generar el hash de la contraseña:

```
root@stucom:/etc# mkpasswd --method=sha-512 --salt=xf1d3PSUwpXKwb5C stucom
$6$xf1d3PSUwpXKwb5C$IPYan4HBmKzZU1zBEjiks1mbae0i5UKP091X28ckBRm4ytk1LRDQhTG7H125XYS3aHirjPCFotq2TLFq
Wo3jA0

stucom:$6$xf1d3PSUwpXKwb5C$IPYan4HBmKzZU1zBEjiks1mbae0i5UKP091X28ckBRm4ytk1LRDQhTG7H125XYS3aHirjPCF
otq2TLFqWo3jA0:20136:0:99999:7:::
!xd:!:20136:0:99999:7:::
alex:$y$j9T$0EET9J0xjJz3yBevBJizD.$tiHB9N/N/1Rpu1/95NYRSC.1KdbsJK5zSPL0YCNJ8U9:20147:0:99999:7:::
```

Como vemos, es la misma, por lo que certificamos que la contraseña es «stucom».

C. Firmas digitales y certificación de documentos

Las funciones hash se utilizan en firmas digitales para **garantizar que un documento no ha sido modificado** después de haber sido firmado. Primero se calcula el hash del documento y, a continuación, se cifra este hash con la clave privada del firmante. El receptor puede descifrarlo usando la clave pública del firmante y compararlo con un hash recalculado del documento recibido.

EJEMPLO

Un **documento PDF** se firma digitalmente. La aplicación de firma calcula el hash del PDF y lo cifra. Cuando se abre el PDF en un visor de documentos, se recalcula el hash. Si ambos valores coinciden, se confirma que el documento es auténtico y no ha sido alterado.

D. Uso en tecnologías blockchain

En el mundo de las criptomonedas, como Bitcoin, las funciones hash (por ejemplo, SHA-256) son fundamentales para crear el bloque de la cadena y para asegurar que cualquier cambio en un bloque modifique su hash. Esto hace que la manipulación de datos en blockchain sea prácticamente inviable, ya que cualquier intento de alteración se detecta inmediatamente.

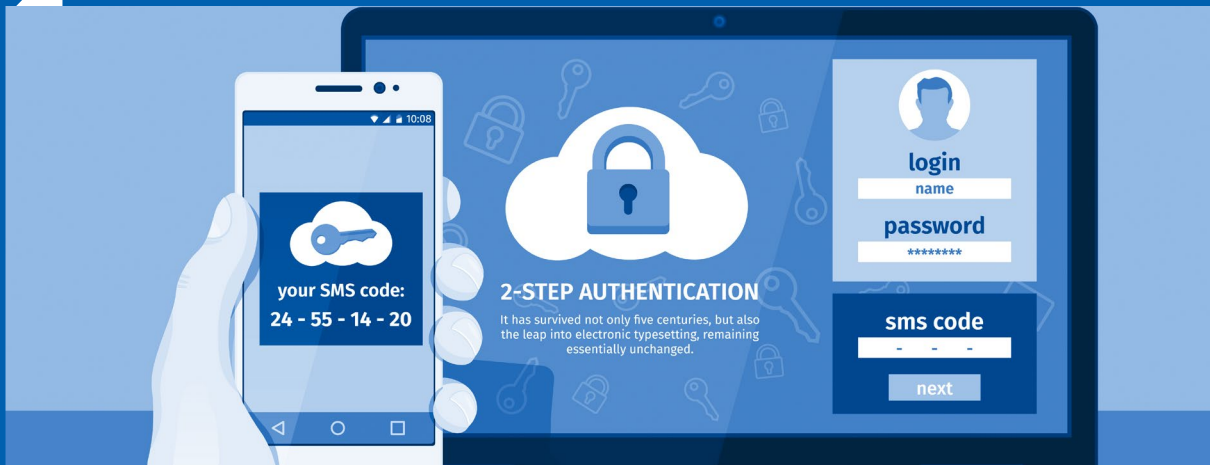
Ejemplo práctico: cada bloque en la cadena de Bitcoin contiene el hash del bloque anterior. Si alguien intenta modificar una transacción, el hash del bloque cambiará, rompiendo la cadena y haciendo evidente la manipulación.

E. Algoritmos de hash

Existen varios algoritmos de hash, cada uno con sus ventajas y limitaciones. Por ejemplo, **MD5** (Message Digest 5) fue ampliamente utilizado en el pasado, pero hoy en día se considera inseguro debido a que es susceptible a colisiones, es decir, a la posibilidad de que dos mensajes distintos generen el mismo hash. En contraste, **SHA-256** (Secure Hash Algorithm) es un algoritmo robusto que se utiliza en aplicaciones críticas, como en firmas digitales y en la tecnología blockchain, donde se emplea en criptomonedas como Bitcoin.

Además, algoritmos como **Bcrypt** y **Argon2** han sido diseñados específicamente para el almacenamiento seguro de contraseñas, ya que incorporan mecanismos que dificultan los ataques de fuerza bruta al ralentizar el proceso de verificación.

2 CASO PRÁCTICO



PROCESOS EN CRIPTOGRAFÍA

Trabajas en una empresa que necesita enviar información confidencial a una sucursal ubicada en otra ciudad:

- » **Con cifrado simétrico:** el director de innovación cifra el informe con una clave secreta conocida por ambas partes. El informe cifrado se envía a la sucursal, donde se descifra con la misma clave.
- » **Con cifrado asimétrico:** la sucursal genera su par de claves y envía la clave pública al director. Este cifra el informe con dicha clave pública, garantizando que solo la sucursal (que posee la clave privada correspondiente) pueda descifrar el documento.

Ahora, explica cuáles son los pasos necesarios para llevar a cabo estos dos tipos de cifrado, el simétrico y el asimétrico.

03 Sistemas de identificación

3.1. Cifrar y firmar

La criptografía tiene dos objetivos fundamentales: **garantizar la confidencialidad y asegurar la autenticidad de la información**. Para proteger la confidencialidad, se cifra el mensaje original de modo que solo el destinatario previsto pueda leerlo. Por otro lado, para asegurar que el emisor es quien dice ser, se utiliza el mecanismo de firma digital.

En este proceso, el emisor comienza por generar un resumen o hash del documento utilizando una función hash. Este resumen es **único** para cada mensaje, de forma que cualquier cambio, incluso mínimo, modifica drásticamente su valor. Luego, el emisor cifra este resumen con su clave privada, creando así la firma digital. Al enviar el documento original junto con la firma, el receptor puede, al recibirlos, calcular el hash del documento y, usando la clave pública del emisor, descifrar la firma. Si ambos resúmenes coinciden, se garantiza que el documento es auténtico y no ha sido alterado.

```
root@srv:/home/alex# gpg --clearsign archivo.txt
```

```
root@srv:/home/alex# cat archivo.txt.asc
-----BEGIN PGP SIGNED MESSAGE-----
Hash: SHA512

mensaje a enviar
-----BEGIN PGP SIGNATURE-----

iQGzBAEBCgAdFiEELYe2UR+X+exLhv4UsiWiHwwwKTEFamfCPYkACgkQsiWiHwww
KTFs6Av9FWHng/J5b8DZIkzcy6sK9MFowtAIJnm9tfGQu+5XCqaT2vJ20twjW21
coLLs+ti46toM8KAwb0PGvpkzLgSr5R2TARUBHNVIGMxBgJ+2bST9ET2L60YBdbY
QdmJLzidoAbVntXSDLu+rINaCJwQ2iY+2rfTeAFP2SJMT6FIahz2WSBUmeamMf+3
DTzTSJ6GgsV6Ae4fEtbwUX2tYDmg0jo4oBg8z3wW4qy+oWd13mfEmoY319Sgrkh4
Wj1biYaknpohyyXVeSyqByDBfE5dgHfRCodpGFetaNK4XQoiNX/EnqX1Mvy+gRgV
6TumuV7Pgpth9j0Nn58p2c2tdCA6AxWEFVsRB1KUGdCM1jYITqr9LqJmdWLS0Upi
3pk8S5xkd24JFMhh4b30NAhGHJe0zAMiLh0aBchmo4V3kEzWm6iqugDdlaaI5AYP
Wb8guiWJQGDTf+oCgniocW2KL/FSDwTimwa4qXci+tk+1XN5dLQfbGCJH8pUi9jN
DdcT2AJS
=020u
-----END PGP SIGNATURE-----
root@srv:/home/alex#
```

Se transfiere al destinatario el archivo firmado:

```
root@srv:/home/alex# scp archivo.txt.asc stucom@10.0.2.13:/home/stucom
stucom@10.0.2.13's password:
archivo.txt.asc                                100% 725   164.5KB/s   00:00
root@srv:/home/alex# _
```

En el destino, verificamos la firma:

```
root@stucom:/home/stucom# gpg --verify archivo.txt.asc
gpg: Signature made vie 28 feb 2025 22:49:45 UTC
gpg: using RSA key 2D87B6511F97F9EC4B86FE14B225A21F0C302931
gpg: Good signature from "Alfonso (text) <alfonso@uax.net>" [unknown]
```

Todo es correcto.

Con lo anterior hemos asegurado la autenticidad, pero, para agregar una capa de **confidencialidad** en la transmisión, se cifra el documento original utilizando la clave pública del receptor. De esta forma, solo el destinatario, con su clave privada, podrá descifrarlo. Este doble proceso —firma para autenticidad y cifrado para confidencialidad— es esencial en comunicaciones seguras, como en la autenticación sin contraseña o en el intercambio de documentos oficiales.

3.2. Infraestructura de clave pública (PKI)

Hasta ahora, en los apartados anteriores, nos hemos centrado en enviar documentos de forma que solo el destinatario pueda leerlos (mediante el cifrado) y, al mismo tiempo, que se garantice que el documento provenga realmente de nosotros (mediante la firma digital). Sin embargo, en cada caso hemos tenido que comprobar manualmente que la clave pública con la que comunicamos es auténtica, comparando su huella digital con la original. Esto es sencillo cuando trabajamos en la misma máquina o en dispositivos cercanos, pero la realidad es que la mayoría de las comunicaciones seguras se dan entre equipos ubicados a **grandes distancias** y, a menudo, pertenecientes a **diferentes organizaciones**, como las oficinas virtuales de un banco o los servicios de correo web. En esos casos, no podemos acceder físicamente a cada máquina para verificar manualmente las huellas digitales de las claves ni establecer un canal seguro individual para hacerlo.

La solución a este problema es la implantación de una infraestructura de clave pública (PKI).

A. Estructura

Con la PKI intervienen nuevos actores en el proceso de comunicación segura entre cliente y servidor:

- » **Autoridad de certificación (CA):** es una entidad de confianza que emite y firma certificados digitales. Estos certificados son como «documentos de identidad» electrónicos que vinculan la identidad de una persona, empresa o sitio web con su clave pública. La CA verifica que quien solicita el certificado es realmente quien dice ser, y luego firma digitalmente el certificado. Esto permite que otras partes confíen en la autenticidad de la clave pública, ya que saben que ha sido validada por una fuente confiable. Algunas CA son:

- **Let's Encrypt:** proporciona certificados digitales gratuitos y automatizados, facilitando la implementación de HTTPS en sitios web.
 - **DigiCert:** una de las CA más importantes, conocida por ofrecer certificados SSL/TLS de alta seguridad para empresas y organizaciones.
 - **GlobalSign:** emite certificados digitales para asegurar sitios web, correos electrónicos y otros servicios digitales.
 - **Sectigo:** ofrece una amplia gama de soluciones de seguridad digital, incluyendo certificados SSL/TLS.
- » **Autoridad de registro (RA):** es la entidad encargada de verificar la identidad de las personas o empresas que solicitan un certificado digital. En otras palabras, antes de que se emita un certificado, la RA recopila y comprueba la documentación necesaria —como el DNI, el pasaporte u otros documentos oficiales— para asegurarse de que el solicitante es realmente quien dice ser. Una vez validada esta información, la RA autoriza la solicitud y la remite a la autoridad de certificación (CA), que se encarga de emitir y firmar el certificado digital. Este proceso garantiza que los certificados solo se entreguen a usuarios legítimos, haciendo que las comunicaciones y transacciones digitales sean más seguras y confiables. Por ejemplo, algunos casos de RA son:
- **FNMT-RCM (Fábrica Nacional de Moneda y Timbre-Real Casa de la Moneda):** en España, esta entidad actúa como RA para emitir certificados digitales y el DNle, verificando la identidad de los solicitantes mediante documentación oficial.
 - **RA internas de empresas certificadoras:** muchas empresas que emiten certificados digitales, como DigiCert o GlobalSign, cuentan con departamentos o servicios de RA que se encargan de validar la identidad de los clientes antes de que se les emita un certificado.
- » **Autoridad de validación (VA):** es la entidad encargada de confirmar que un certificado digital sigue siendo válido y confiable. Esto implica comprobar que el certificado:
- **No ha expirado:** verifica que la fecha actual esté dentro del periodo de validez indicado en el certificado.
 - **No ha sido revocado:** consulta listas de revocación (CRL) o utiliza protocolos como OCSP (Online Certificate Status Protocol) para asegurarse de que el certificado no haya sido desactivado antes de su fecha de caducidad.
 - **Es auténtico:** comprueba que la firma digital en el certificado, realizada por la autoridad de certificación (CA), sea correcta y que la información contenida en él no haya sido alterada.



¿SABÍAS QUE...?

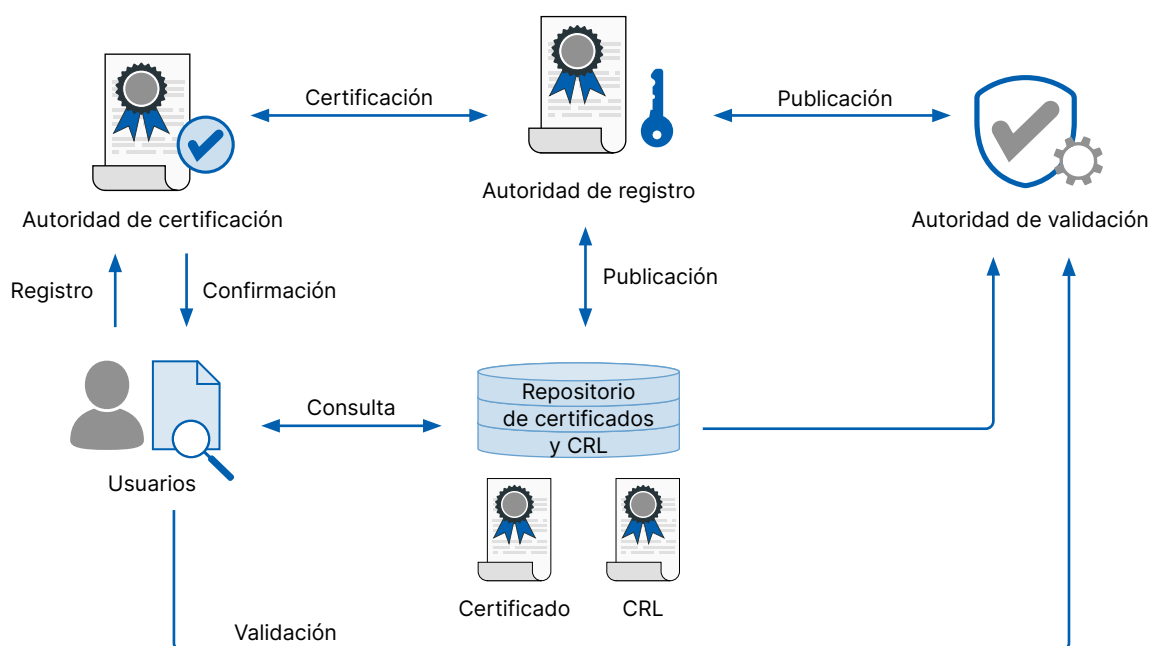
En la práctica, **muchas VA están integradas en las propias CA**, ya que se encargan de proporcionar respuestas que confirman la vigencia de los certificados a través de mecanismos como OCSP (Online Certificate Status Protocol) o mediante listas de revocación (CRL).

- » **Repositorios:** son almacenes donde se guardan los certificados activos y las listas de revocación, que contienen aquellos certificados que han sido desactivados antes de su fecha de caducidad.

B. Funcionamiento

El funcionamiento de la estructura PKI es el siguiente:

1. Cuando se inicia una sesión segura, el servidor envía su clave pública junto con una firma digital realizada por una CA.
2. El cliente, antes de usar esa clave, verifica la firma utilizando la clave pública de la CA, que ya debería estar almacenada en su llavero de claves.
3. Si la verificación es correcta, el cliente puede confiar en que la clave pública del servidor es auténtica y establecer una conexión segura.



Esquema 2. Funcionamiento de la estructura PKI.

Veremos un caso más concreto en el apartado de certificados digitales.

3.3. Certificados digitales

DEFINICIÓN

Un **certificado digital** es un documento electrónico que vincula la identidad de una entidad (persona, empresa o servidor) con una clave pública. Este certificado incluye información como el nombre del titular, la clave pública, las fechas de validez y otros detalles relevantes, y está firmado digitalmente por una autoridad de certificación (CA). La firma de la CA garantiza que la clave pública realmente pertenece a la entidad que se indica en el certificado.

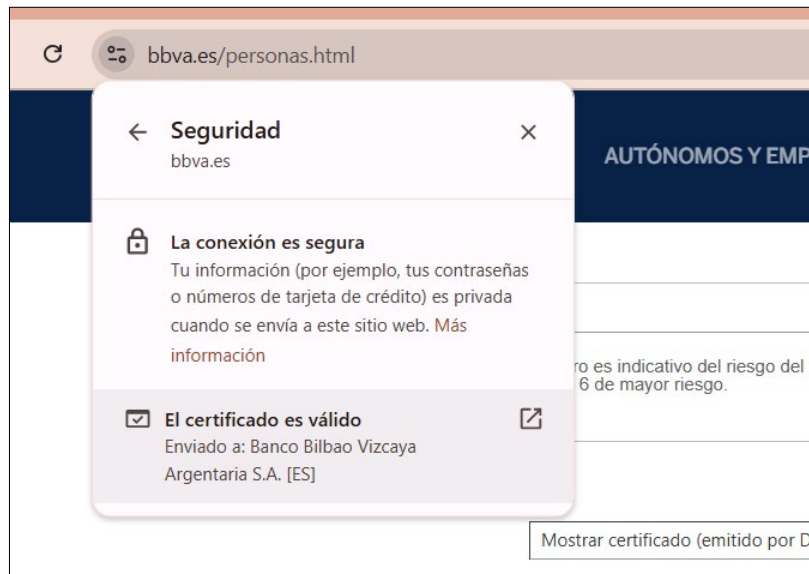
Podemos ver un ejemplo de este concepto cuando tratamos de verificar la identidad de quien está detrás de un sitio web.



IMPORTANTE

Antes de hacer una operación por Internet, será imprescindible **asegurarnos de quién está detrás**, no vaya a ser que demos nuestros datos de acceso a la banca online a un ciberdelincuente.

Para ello, tenemos los certificados digitales.



Como vemos en la anterior imagen, este sitio web tiene un certificado válido y enviado al Banco Bilbao Vizcaya Argentaria S.A., precisamente el banco al que nos dirigíamos a hacer nuestra operación.

En la siguiente imagen, vemos que la entidad que dice que este certificado pertenece al BBVA es DigiCert, Inc.



En este certificado vemos además el **periodo de validez** y cuál es la **clave pública** para poder descryptar la información que nos llega al navegador vía HTTPS desde este sitio web, que se envía encriptado con la clave privada del BBVA.



WEB

Explicación de cómo funcionan los certificados SSL en la web:

<https://www.youtube.com/watch?v=SJJmoDZ3il8>

Además de lo anterior, es posible crear **certificados autofirmados** con el objetivo de hacer pruebas. Como es obvio, estos certificados no ofrecerían ningún tipo de seguridad, puesto que seríamos nosotros mismos los que decimos que somos nosotros; sin embargo, para la configuración de test de un servidor HTTPS pueden ser válidos.

En la siguiente imagen, creamos la clave para el certificado:

```
root@stucom:/etc/apache2# openssl genrsa -des3 -out server.key 3072
Enter PEM pass phrase:
Verifying - Enter PEM pass phrase:
```

Y, a continuación, creamos una solicitud de certificado .csr a partir de la clave que ya hemos creado:

```
root@stucom:/etc/apache2# openssl req -new -key server.key -out server.csr
Enter pass phrase for server.key:
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:ES
State or Province Name (full name) [Some-State]:Barcelona
Locality Name (eg, city) []:Barcelona
Organization Name (eg, company) [Internet Widgits Pty Ltd]:Stucom
Organizational Unit Name (eg, section) []:Informatica
Common Name (e.g. server FQDN or YOUR name) []:websegura.alex.local
Email Address []:info@stucom.com

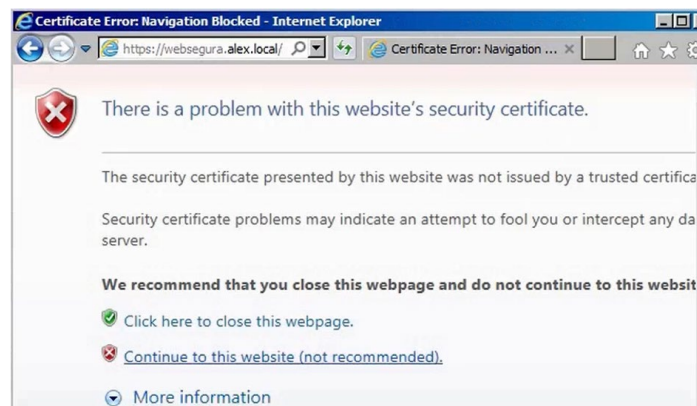
Please enter the following 'extra' attributes
to be sent with your certificate request
```

En esta solicitud de certificado, incluimos nuestros datos personales, que son los que la CA debería certificar, aunque, en este caso particular, no lo vamos a exponer a una CA, sino que crearemos un certificado autofirmado para usarlo en pruebas de laboratorio.

Aquí vemos que se crea ese certificado autofirmado:

```
root@stucom:/etc/apache2# openssl x509 -req -days 365 -in server.csr -signkey server.key -out server.crt
Certificate request self-signature ok
```

Cuando usamos un certificado autofirmado, el navegador nos avisa con una alerta parecida a la de la siguiente imagen:



Este aviso indica que no podemos confiar en que quien esté detrás de este certificado sea quien dice ser porque no hay una CA que lo certifique; sin embargo, para entornos de prueba en que debemos usar el protocolo HTTPS es suficiente.



VIDEOLAB

Para consultar el siguiente vídeo sobre **Garantizar la autenticidad y la confidencialidad**, escanea el código QR o [pulsa aquí](#).

Aprenderemos a firmar un documento con firma digital para garantizar la autenticidad. Veremos cómo se cifra el documento con un par de claves para certificar la confidencialidad en entorno Windows.

3 CASO PRÁCTICO



COMUNICACIÓN SEGURA EN UN ENTORNO BANCARIO

En un banco se necesita enviar un informe financiero muy sensible desde una sucursal a la sede central. Para garantizar que la información no pueda ser leída por terceros y que provenga realmente del remitente, se implementa un sistema de comunicación seguro que combina el cifrado, la firma digital y una infraestructura de clave pública (PKI).

Para garantizar la autenticidad y la integridad, indica qué acciones se tomarán y en qué orden.

Solucionario de los casos prácticos

1

SOLUCIÓN CASO PRÁCTICO



CIFRADO CÉSAR EN UNA COMUNICACIÓN SECRETA

DWDTXH DO DPDQHCHU

2 SOLUCIÓN CASO PRÁCTICO



PROCESOS EN CRIPTOGRAFÍA

» Cifrado simétrico:

1. El documento cifrado se envía a través de un canal de comunicación.
2. El emisor aplica un algoritmo de cifrado al documento usando una clave secreta.
3. El receptor utiliza la misma clave secreta para descifrar el documento y recuperar la información original.

» Cifrado asimétrico:

1. El receptor genera un par de claves: una pública y una privada.
2. El receptor distribuye su clave pública al emisor.
3. El emisor cifra el documento usando la clave pública del receptor.
4. El documento cifrado se envía al receptor.
5. El receptor descifra el documento utilizando su clave privada.

3 SOLUCIÓN CASO PRÁCTICO



COMUNICACIÓN SEGURA EN UN ENTORNO BANCARIO

- 1. Generación del resumen (hash):** el director de la sucursal prepara el informe y, antes de enviarlo, se calcula un hash del documento utilizando una función hash (por ejemplo, SHA-256). Este resumen es único y se verá afectado por cualquier cambio en el documento.
- 2. Creación de la firma digital:** con su clave privada, el director cifra el hash, creando la firma digital. De esta forma, se garantiza que el informe realmente proviene de él y no ha sido alterado en el proceso.
- 3. Envío del documento y la firma:** el informe original se envía junto con la firma digital. El receptor, al recibir ambos, puede recalcular el hash del documento y usar la clave pública del director para descifrar la firma. Si ambos hashes coinciden, se confirma la autenticidad y la integridad del mensaje.
- 4. Distribución de claves mediante PKI:** tanto la sucursal como la sede central disponen de certificados digitales emitidos por una CA confiable (por ejemplo, DigiCert o GlobalSign). Estos certificados vinculan las claves públicas a la identidad de cada entidad y están almacenados en un repositorio seguro.
- 5. Cifrado del mensaje:** el director utiliza la clave pública de la sede central para cifrar el informe (ya firmado). Al hacerlo, el mensaje se convierte en datos ininteligibles para cualquier tercero.
- 6. Transmisión del mensaje cifrado:** el informe cifrado se transmite por la red (por ejemplo, mediante HTTPS o un túnel VPN), reduciendo el riesgo de interceptación.

7. **Descifrado del informe:** al llegar a la sede central, el equipo receptor utiliza su clave privada para descifrar el documento. Solo ellos pueden acceder al contenido, ya que son los únicos en posesión de la clave privada correspondiente a su certificado.
8. **Verificación de la firma digital:** una vez descifrado, el receptor recalcula el hash del informe y utiliza la clave pública del director (obtenida a través de su certificado digital, previamente validado mediante la PKI) para descifrar la firma. Si el hash obtenido coincide con el recalculado, se confirma que el documento es auténtico y que no ha sido modificado.

Enlaces de interés

¿Cómo funcionaba la máquina Enigma?

<https://www.youtube.com/watch?v=ybkkiGtJmkM>

Más información sobre cifrado simétrico:

https://www.redseguridad.com/actualidad/cifrado-simetrico-que-es-usos-tecnicas_20231104.html

Información sobre Blowfish:

https://www.schneier.com/academic/archives/1998/12/the_twofish_encrypti.html

Encriptación asimétrica:

<https://www.ionos.es/digitalguide/servidores/seguridad/cifrado-asimetrico/>

CA LetsEncrypt: <https://letsencrypt.org/>

CA DigiCert: <https://www.digicert.com/>

CA GlobalSign: <https://www.globalsign.com/en>

CA SectiGo: <https://www.sectigo.com/es>

Casa de la moneda. RA: <https://www.fnmt.es/>

Información sobre qué es PKI, más detalles:

<https://www.entrust.com/es/resources/learn/what-is-pki>

Explicación de cómo funcionan los certificados SSL en la web:

<https://www.youtube.com/watch?v=SJJmoDZ3il8>

Glosario

- » **AES (Advanced Encryption Standard):** Algoritmo de cifrado simétrico ampliamente utilizado en seguridad informática, con claves de 128, 192 o 256 bits.
- » **Algoritmo de cifrado:** Conjunto de reglas matemáticas utilizadas para transformar datos en información cifrada.
- » **Autenticación:** Proceso que verifica la identidad de un usuario o sistema antes de otorgar acceso a la información.
- » **Autoridad de certificación (CA):** Entidad que emite y firma certificados digitales para verificar la autenticidad de claves públicas.
- » **Autoridad de registro (RA):** Entidad que valida la identidad de los solicitantes de un certificado digital antes de que la CA lo emita.
- » **Autoridad de validación (VA):** Organismo encargado de verificar la vigencia y la autenticidad de un certificado digital.
- » **Blockchain:** Tecnología basada en cadenas de bloques protegidas con funciones hash, utilizada en criptomonedas y seguridad de datos.
- » **Blowfish:** Algoritmo de cifrado simétrico rápido y seguro, utilizado en diversas aplicaciones de seguridad.
- » **Cifrado asimétrico:** Método de encriptación que utiliza un par de claves, una pública y una privada, para cifrar y descifrar datos.
- » **Cifrado Atbash:** Método de cifrado clásico que invierte el orden del alfabeto para transformar un mensaje.
- » **Cifrado César:** Técnica de cifrado clásico que consiste en desplazar las letras del alfabeto un número fijo de posiciones.
- » **Cifrado de clave pública:** Sistema de cifrado en el que los datos se encriptan con una clave pública y solo pueden ser descifrados con la clave privada correspondiente.
- » **Cifrado de clave secreta:** También llamado cifrado simétrico, utiliza una misma clave para cifrar y descifrar la información.

- » **Cifrado Playfair:** Método de cifrado clásico que emplea una matriz de 5×5 para sustituir pares de letras en un mensaje.
- » **Cifrado simétrico:** Técnica de encriptación donde la misma clave es utilizada tanto para cifrar como para descifrar los datos.
- » **Confidencialidad:** Propiedad que garantiza que la información solo sea accesible para personas autorizadas.
- » **Criptografía:** Ciencia que estudia técnicas para cifrar y proteger la información contra accesos no autorizados.
- » **DNI Electrónico (DNle):** Documento de identidad que incorpora un chip con certificado digital para realizar autenticaciones y firmas electrónicas.
- » **DES (Data Encryption Standard):** Algoritmo de cifrado simétrico considerado obsoleto debido a su baja seguridad frente a ataques modernos.
- » **Diffie-Hellman:** Protocolo de intercambio de claves que permite a dos partes generar una clave secreta compartida en un canal inseguro.
- » **ECC (criptografía de curvas elípticas):** Técnica de cifrado asimétrico que ofrece alta seguridad con claves más cortas en comparación con RSA.
- » **Firma digital:** Método que garantiza la autenticidad y la integridad de un documento mediante criptografía asimétrica.
- » **Funciones hash:** Algoritmos que convierten un dato en una cadena única de longitud fija, permitiendo verificar su integridad.
- » **HMAC (Hash-based Message Authentication Code):** Técnica de seguridad que usa una clave secreta combinada con una función hash para garantizar que los datos no han sido alterados.
- » **Integridad:** Propiedad que asegura que los datos no han sido modificados de manera no autorizada.
- » **IPSec (Internet Protocol Security):** Conjunto de protocolos para cifrar y autenticar comunicaciones a nivel de red.
- » **Máquina Enigma:** Dispositivo electromecánico utilizado en la Segunda Guerra Mundial para cifrar y descifrar mensajes.

- » **MD5 (Message Digest 5):** Algoritmo hash que genera resúmenes de 128 bits, considerado inseguro debido a su vulnerabilidad a colisiones.
- » **No repudio:** Garantía de que un emisor no puede negar haber enviado un mensaje o firmado un documento.
- » **OCSP (Online Certificate Status Protocol):** Protocolo utilizado para verificar en tiempo real la validez de un certificado digital.
- » **PKI (Public Key Infrastructure):** Conjunto de tecnologías y procesos que permiten la gestión de claves y certificados digitales para la autenticación y el cifrado.
- » **Repositorios:** Almacenes donde se guardan certificados digitales y listas de revocación de certificados.
- » **RSA (Rivest-Shamir-Adleman):** Algoritmo de cifrado asimétrico basado en la dificultad de factorizar grandes números primos.
- » **SHA-256 (Secure Hash Algorithm 256 bits):** Función hash ampliamente utilizada para verificar la integridad de archivos y datos.
- » **SSL (Secure Sockets Layer):** Protocolo de seguridad predecesor de TLS, usado para cifrar comunicaciones en Internet.
- » **TLS (Transport Layer Security):** Protocolo de seguridad que cifra la comunicación entre dispositivos en Internet, asegurando la confidencialidad de los datos transmitidos.
- » **Twofish:** Algoritmo de cifrado simétrico alternativo a AES, diseñado para ofrecer alta seguridad y velocidad.
- » **VPN (Virtual Private Network):** Tecnología que establece una conexión segura y cifrada sobre una red pública, permitiendo la comunicación privada entre usuarios y servidores.
- » **WPA2/WPA3:** Protocolos de seguridad para redes wifi que emplean cifrado avanzado para proteger las conexiones inalámbricas.

Bibliografía

Molist, M., y Medina, M. (2015). *Cibercrimen*. Tibidabo Ediciones.

Artículo de IONOS sobre cifrado asimétrico. Explica los fundamentos del cifrado asimétrico y su aplicación en certificados digitales. Disponible en: <https://www.ionos.es/digitalguide/servidores/seguridad/cifrado-asimetrico/>

Artículo sobre cifrado simétrico en Red Seguridad. Explica qué es el cifrado simétrico, sus usos y las técnicas más utilizadas. Disponible en: https://www.redseguridad.com/actualidad/cifrado-simetrico-que-es-usos-tecnicas_20231104.html

UAX FP